

Secure Amazon S3 Bucket Configuration and Object-Level Data Protection

Amazon S3 Encryption, Least-Privilege Access & Audit Logging — Junior Cloud Security Engineer Internship

Task Metadata

Task ID	CSE-AWS-L-010-04
Task Title	Secure Amazon S3 Bucket Configuration and Object-Level Data Protection
Internship Program	Junior Cloud Security Engineer Internship
Role	Junior Cloud Security Engineer Intern
Skill Domain	AWS Cloud Security / IAM / S3 Access Control / Threat Detection / STS / IaC Security
Difficulty	Intermediate
Duration	14 Hours
Credit Weight	4 CPE Credits
Target Platform	AWS Free Tier account / PwnedLabs lab / Cybr lab
AWS Region(s)	us-east-2
Primary Tools	AWS CLI, AWS Management Console, AWS KMS, CloudShell, ChatGPT or Claude for AI assistance
MITRE ATT&CK	T1078 (Valid Accounts), T1530 (Data from Cloud Storage Object), T1098 (Account Manipulation)
Guiding Frameworks	CIS AWS Foundations Benchmark v1.5, NIST SP 800-53, ISO 27001, OWASP Cloud Top 10
Regulatory Alignment	ISO 27001 A.9 Access Control, A.12 Operations Security; NICE PR-CDA-001; SFIA Level 3-4
Dependencies	Basic AWS CLI familiarity; an authorised AWS Free Tier lab account.

Learning Outcomes

- 1. Understand S3 security risks and access-control mechanisms, including public access, insecure ACLs, and overly permissive policies, along with appropriate mitigations.
- 2. Configure a secure S3 environment: create a lab bucket, enable Block Public Access and versioning, and configure a customer-managed AWS KMS key for encryption testing.
- 3. Implement encryption and least-privilege access using SSE-KMS and a bucket policy restricted to an authorised IAM user.
- 4. Apply object-level security and audit logging via private object permissions and S3 Server Access Logging to a separate private audit bucket.
- 5. Validate and document S3 security controls by testing anonymous access, reviewing generated access logs, and completing a risk-matrix assessment.

Objectives & Measurable Outcomes

#	Objective	Mapped To
1	Configure a secure S3 lab environment (Block Public Access, versioning, customer-managed KMS key)	CIS AWS Foundations / T1530
2	Encrypt objects at rest with SSE-KMS and restrict access to a least-privilege IAM identity	NIST SP 800-53 AC-6 / T1078
3	Apply private object ACLs and validate that anonymous access is denied	T1530
4	Enable S3 Server Access Logging to a separate private audit bucket	T1562.008 / NIST AU-2
5	Document findings in a risk matrix with MITRE ATT&CK mapping and remediation guidance	ISO 27001 A.12

Tools & Prerequisites

- AWS CLI v2 — verify identity, list buckets, check versioning/public-access/KMS configuration.
- AWS Management Console — create and configure the S3 buckets, KMS key, and IAM permissions.
- AWS KMS — create and manage the customer-managed key (S3LabKey) used for SSE-KMS.
- AWS CloudShell — execute AWS CLI commands and capture command-line evidence.
- ChatGPT or Claude — explain S3/IAM/KMS concepts and assist with report wording only; not used to execute AWS commands.

AI Tool Example Usage: Use AI only to explain SSE-S3 vs. SSE-KMS, IAM/bucket-policy/ACL concepts, or to help troubleshoot permission errors and structure the report. All AWS CLI commands, configurations, and screenshots must be produced independently in the authorised lab environment.

Simplified Legal Scope

Allowed Actions	Prohibited Actions
● Create and configure S3 buckets, IAM permissions, and KMS keys in a personal/authorised AWS lab account. ● Upload, encrypt, and test access on objects the student controls within the lab bucket(s). ● Test anonymous access against objects the student owns to validate access controls. ● Enable and review server access logs delivered to a private audit bucket the student owns.	● No access to unauthorised third-party or production AWS accounts or buckets. ● No use of a production or employer AWS account for lab activities. ● Never expose AWS access keys, session tokens, or account identifiers in the report or public repositories. ● No destructive actions against resources outside the authorised lab scope.

Hands-On Phases

Phase A — Theory & Conceptual Foundation

Objective: Understand the security risks of misconfigured S3 buckets and how encryption and access control mitigate them.

Evidence Required: PhaseA_Summary.pdf

Estimated Time: ~90 minutes

Instructions

- 1 Review common Amazon S3 misconfigurations: public read/write access, overly permissive bucket policies, insecure ACLs.

- 2 Study SSE-S3 vs. SSE-KMS encryption and how IAM roles, bucket policies, and object ACLs interact to control access.
- 3 Summarize the distinction between a bucket policy and an object ACL.

Completion Checklist

- 1 ☐ S3 misconfiguration risks reviewed.
- 2 ☐ SSE-S3 vs. SSE-KMS comparison documented.
- 3 ☐ Bucket policy vs. object ACL distinction summarized.

Phase B — Cloud Environment Setup & Target Preparation

Objective: Create a secure S3 testing environment in your own AWS account.

Evidence Required: PhaseB_config(1).png, PhaseB_config(2).png

Estimated Time: ~120 minutes

Instructions

- 1 Create the secure-s3-lab bucket and enable Block All Public Access.
- 2 Enable bucket versioning for recovery from accidental modification or deletion.
- 3 Create a customer-managed KMS key (alias/S3LabKey) for encryption testing.

Completion Checklist

- 1 ☐ Block Public Access enabled and captured.
- 2 ☐ Versioning enabled and captured.
- 3 ☐ KMS key created and alias documented.

Phase C — Core Execution

Objective: Apply encryption at rest using SSE-KMS and enforce least privilege through IAM policies.

Evidence Required: PhaseC_Encryption.log, PhaseC_Anonymous_Access_Denied.png

Estimated Time: ~150 minutes

Instructions

- 1 Configure SSE-KMS and upload confidential.txt to the lab bucket using alias/S3LabKey.
- 2 Verify encryption via AWS CLI and apply a bucket policy restricting access to the authorised IAM user.
- 3 Test anonymous browser access to the object and confirm AccessDenied.
- 4 Redact access keys, secrets, and account identifiers from all captured evidence.

Completion Checklist

- 1 ☐ Object uploaded with SSE-KMS and verified.
- 2 ☐ Bucket policy enforces least privilege.
- 3 ☐ Anonymous access test returned AccessDenied.
- 4 ☐ Evidence redacted before submission.

Phase D — Independent Extension & Advanced Implementation

Objective: Extend security by applying object ACLs and enabling logging for auditability.

Evidence Required: PhaseD_Logs.png

Estimated Time: ~90 minutes

Instructions

- 1 Set the object ACL on confidential.txt to private.
- 2 Create a separate private audit bucket and enable S3 Server Access Logging on the primary bucket.

- 3 Perform read/write/list operations to generate activity and verify log delivery to the audit bucket.

Completion Checklist

- 1 ☐ Object ACL set to private.
- 2 ☐ Server access logging enabled to a separate audit bucket.
- 3 ☐ Log delivery verified after test activity.

Phase E — Hosted Lab Integration

Objective: Reinforce S3 security concepts using an authorised hosted lab platform (e.g. PwnedLabs or Cybr).

Evidence Required: Hosted lab completion proof (badge/screenshot) as required by the task brief

Estimated Time: ~90–120 minutes

Instructions

- 1 Complete the assigned hosted lab module relevant to S3 security.
- 2 Capture completion evidence (badge, certificate, or screenshot).

Completion Checklist

- 1 ☐ Hosted lab completed.
- 2 ☐ Completion evidence captured.

Phase F — Documentation & Reporting

Objective: Compile findings into a professional report demonstrating secure configuration practices.

Evidence Required: CSE_CSE-AWS-L-010-04_[date].pdf

Estimated Time: ~60–90 minutes

Instructions

- 1 Compile all lab activities, configurations, findings, and the risk matrix into the EncryptEdge Labs report template.
- 2 Document the controls implemented for encryption, access management, object permissions, and logging.
- 3 Review the report for secret/identifier leakage before submission.

Completion Checklist

- 1 ☐ All phases documented with evidence references.
- 2 ☐ Risk matrix completed.
- 3 ☐ Report reviewed for redaction before submission.

Deliverables

Phase	File	Description
A	PhaseA_Summary.pdf	One-page summary of S3 misconfigurations, SSE-S3 vs. SSE-KMS, and access-control concepts.
B	PhaseB_config(1).png, PhaseB_config(2).png	Block Public Access, versioning, and KMS configuration screenshots.
C	PhaseC_Encryption.log, PhaseC_Anonymous_Access_Denied.png	SSE-KMS encryption/upload evidence and failed anonymous access test.
D	PhaseD_Logs.png	Private audit bucket showing delivered server access logs.
E	Hosted lab completion evidence	Proof of completion for the assigned hosted lab module.

Phase	File	Description
F	CSE_CSE-AWS-L-010-04_[date].pdf	Final task report: methodology, findings, risk matrix, and recommendations.

Note: All deliverables should be packaged in ZIP or RAR format. The EncryptEdge Labs Report Template must be used for the main report.

Evaluation Rubric — Total: 10 Points

Criterion	Description	Points
Challenge/Task Execution & Evidence	Correct completion of all phases with reproducible, scoped evidence.	2
Technical Analysis & Root-Cause Reasoning	Accurate explanation of the relevant AWS services, misconfigurations, and attack paths.	2
Hardening, Detection & Risk Prioritization	Practical preventive/detective controls, validation, and risk ratings.	2
Documentation & Professional Practice	Clear report structure, evidence organization, and adherence to legal scope.	2
Operational Safety & Redaction	Use of an authorised lab/sandbox, credential/ID redaction, and safe cloud operations.	2

Reflection Questions

- Q1. How does enabling versioning contribute to data resilience during ransomware attacks?
- Q2. What business risks arise if an organization fails to encrypt sensitive data stored in S3?
- Q3. How would you design a monitoring strategy for detecting unauthorized object downloads?
- Q4. If you discovered a misconfigured public bucket belonging to another company, what ethical steps should you take?